Proxy data-flow map

```
Browser/client
  | request: token + topicId only
  v
Vercel/API gateway boundary
  | never accepts student records, free text, attachments, or user-selected tenant au
  v
[1 identity/context] --deny--> metadata-only audit --> refusal
  v
[2 classification] --deny--> metadata-only audit --> refusal
  v
[3 policy/consent/budget] --deny--> release reservation --> refusal
  v
[4 retrieval/egress] --deny--> release reservation --> refusal
  | provider payload = { reviewed prompt, allowedAnswerCode }
  | excludes token, actor, tenant, student/private records, source body, user text ar
  v
[5 provider route/tools] --deny--> release reservation --> refusal
  | model generation only; no tools in reference
  v
[6 output/release] --deny--> release reservation --> refusal
  v
AI-assisted answer + approved source ID + policy version + uncertainty
  v
metadata-only audit + settle budget
```

The provider sees only two fields in the reference implementation: a reviewed prompt and a catalog answer code. It does not see the identity token, tenant/school scope, policy object, source text, source digest, user free text, attachments, student record, conversation history, or audit record.

For an approved future retrieval system, untrusted document text remains data, never instructions. Retrieval results use source-specific authorization and classification before egress. For a future tool action, the model produces a proposal; a canonical domain command verifies permission, exact approval, version and workflow state before execution. OWASP recommends authorizing tools in the execution component rather than relying on agent context. [web:113]